Black Hat Asia 2025 – Example of High Scoring Submission

Proposal Info
Title
Tinker Tailor LLM Spy: Investigate & Respond to Attacks on GenAI Chatbots

Status
Accepted

Session Type
Briefings

Speaker
Allyn Stott (Senior Staff Engineer, Airbnb)

Tracks
AI, ML, & Data Science; Threat Hunting & Incident Response

Format
40-Minute Briefings

Abstract
It's coming, and you aren't ready—your first generative AI chatbot incident. GenAI chatbots, leveraging LLMs, are revolutionizing customer engagement by providing real-time, automated 24/7 chat support. But when your company's virtual agent starts responding inappropriately to requests and handing out customer PII to anyone that asks nicely, who are they going to call? You.
You've seen the cool prompt injection attack demos and may even be vaguely aware of preventions like LLM guardrails; but are you ready to investigate and respond when those preventions inevitably fail? Would you even know where to start? It's time to connect traditional investigation and response procedures with the exciting new world of GenAI chatbots.
In this talk, you'll learn how to investigate and respond to the unique threats targeting these systems. You'll discover new methods for isolating attacks, gathering information, and getting to the root cause of an incident using AI defense tooling and LLM guardrails. You'll come away from this talk with a playbook for investigating and responding to this new class of GenAI incidents and the preparation steps you'll need to take before your company's chatbot responses start going viral—for the wrong reasons.

Presentation Outline – NOTE THE DETAILED OUTLINE
1. INTRODUCTION
"Oh no, not another GenAI/LLM talk." But this one is different. While we've extensively discussed attacks and protections surrounding generative artificial intelligence (GenAI) and Large Language Models (LLMs), those of us on the incident response side haven't yet had the opportunity to join the party. And we would like to jump into this rapidly advancing technology party before the inevitable incident.
In this part of the talk, I will share a brief overview of GenAI chatbot technologies and common architectures.
2. GENAI CHATBOT RISKS
To lay the foundation, I'll discuss the varying levels of risk posed by GenAI chatbots:
1) Chatbot provides info
2) Chatbot provides info that contains PII
3) Chatbot performs actions

I'll then briefly discuss specific GenAI chatbot risks including data exposure, model misuse, output manipulation, unauthorized or malicious actions, resource consumption, data poisoning, and training-set vulnerabilities.

3. GENAI CHATBOT DEFENSE TOOLING

The incident response team should have a current, in-depth understanding of the design, controls and threat model of the AI application architecture. We want to avoid catching up with the AI system owners in the middle of an incident in terms of walking through the data flows, understanding control points, and recommending control options.

In this section, I'll introduce common defense tools that perform input sanitization, output validation, and content moderation. I'll discuss how guardrails work to parameterize, label, and score input and outputs. I'll discuss the different type guardrails: jailbreaking, prompt guard, relevance, appropriateness, content quality, and edge cases. I'll provide examples of the different guardrail techniques used to regulate chatbot dialogue:

1) Rule-based computation
2) LLM-based metrics
3) LLM judges
4) Prompt engineering and Chain-of-thought

4. INCIDENT SCENARIO: PROMPT INJECTION LEADS TO RCE

Now, with a baseline understanding of how GenAI chatbots work and the common defenses used, I will bring the audience along with me into an incident scenario where harmful requests via prompt injections have led to remote code execution (RCE). I'll walk through the investigation steps required to trace the activity back to the originating attack vector, find the malicious requests, and determine the scope of the incident. Finally, I'll provide some options to contain and remediate the incident.

5. INCIDENT SCENARIO: CHATBOT GOES VIRAL FOR TOXIC CONTENT

In the next scenario, a chatbot is responding with toxic and harmful content leading to public backlash and brand damage. I will detail how to identify and mitigate the spread of this content, followed by an investigation into how the toxic content was generated and the steps to correct the underlying issue. I'll discuss considerations like whether preventions are in-line or in alert-only mode, how to handle malicious prompts that are going viral, and the value of having chatbots behind authentication (and the new value that places on compromised credentials). I'll discuss response strategies for stopping viral prompts from overwhelming resources.

I'll discuss how containment, eradication, and recovery of these incidents differ from other incident scenarios. In this example, the incident involves an attack pattern where the model can be exploited to insult Taylor Swift's music (sacrilege, right?). Remediation would likely involve tuning guardrails and possibly using custom models. However, validating that the remediation is effective against this pattern of abuse would require the ability to re-test at scale and dynamically. Therefore, teams should consider building the capability to do this—ideally with more sophistication than having a couple of people test a couple of abusive prompts.

6. INCIDENT SCENARIO: MODEL INVERSION LEADS TO PII BREACH

In the final scenario, I'll discuss a model inversion attack aimed at extracting PII from a chatbot. I'll walk through forensic investigation techniques that can be used to understand the scope of the breach and identify the compromised data. I'll discuss the need to re-evaluate your typical subject matter experts and forensic firms when dealing with GenAI-related security incidents.

7. CONCLUSION & TAKEAWAYS

I'll conclude the talk by summarizing key points from each incident analysis, emphasizing common themes in detection, investigation, and response strategies. I'll derive a consolidated playbook from the discussed incidents and present actionable steps for incident preparedness, rapid response, and post-incident recovery.

Is This Content New (Not Previously Presented/Published)?

This is all new content that has not been previously published.

Have You/Do You Plan to Submit This Talk to Another Conference?

Currently, I have no plans to submit this talk to another conference.

What new research, concept, technique, or approach is included in your submission?

I will be presenting a brand-new approach to investigating and responding to GenAI chatbots. There has been lots of content from the community extensively discussing attacks and protections surrounding generative artificial intelligence

(GenAI) and Large Language Models (LLMs). But there is a lack of research and content that approaches this new technology from the incident response point-of-view.

Provide 3 Audience Takeaways.
1. A crash course specifically tailored for incident responders in GenAI-powered LLM chatbots, the threat landscape, and defenses.
2. Practical methods to investigate and respond to GenAI chatbot anomalies, suspicious activities, and incidents.
3. Ready-to-implement incident response playbooks and preparation steps tailored for GenAI systems.

If applicable, what problem does your research solve?
This research solves the problem of unpreparedness for investigating and responding to security incidents involving GenAI chatbots, a rapidly emerging class of technology with unique risks and challenges.
Traditional incident response teams lack frameworks and playbooks tailored to the distinct vulnerabilities of LLM-driven systems, such as prompt injection, model inversion, and toxic content generation. The talk bridges this gap by:
A) Adapting Traditional IR Practices: Connecting established detection and response techniques to GenAI-specific challenges, enabling teams to confidently handle incidents like PII leaks, RCE via prompt injection, and brand-damaging outputs.
B) Providing Practical Playbooks: Offering actionable, ready-to-implement strategies for investigating and mitigating incidents involving AI guardrails, model behaviors, and output manipulation.
C) Enhancing Preparedness: Equipping incident responders with the knowledge to anticipate and mitigate GenAI incidents before they escalate into crises, including tools, techniques, and prevention strategies that address AI-specific risks.
This talk addresses the critical need for incident response methodologies that align with the operational realities and risks of generative AI chatbots, ensuring organizations can safeguard sensitive data, maintain trust, and minimize downtime when the inevitable incident occurs.

Will You Be Releasing a New Tool? If Yes, Describe the Tool.
No

Is This a New Vulnerability? If Yes, Describe the Vulnerability.
No

Will Your Presentation Include a Demo? If Yes, Describe the Demo.
No

Provide the Names of the Speakers Presenting and Their Previous Speaking Experience.
Allyn Stott
Black Hat Asia 2024: The Fault in Our Metrics: Rethinking Detection & Response
Black Hat MEA 2024: The Fault in Our Metrics: Rethinking Detection & Response
Black Hat Europe 2023: How I Learned to Stop Worrying and Build a Modern Detection & Response Program

Does Your Company/ Employer Provide a Solution to the Issue Addressed? If Yes, Please Provide Details.
No

Do You Want to Provide a White Paper for Review by the Board?
No

Black Hat Asia 2025 – Example of High Scoring Submission

Proposal Info

Title
State Manipulation: Unveiling New Attack Vectors in Bluetooth Vulnerability Discovery through Protocol State Machine Reconfiguration

Status
Accepted

Session Type
Briefings

Speakers
Lidong Li, (Chief Security Officer, SouceGuard)
Oliver Dong, (CEO, SouceGuard)
Xiao Wang, (Senior Security Researcher, SouceGuard)

Additional Contributor
Lewei Qu, (Security Architect, ByteDance)

Tracks
Exploit Development & Vulnerability Discovery; Cyber-Physical Systems & IoT

Format
30-Minute Briefings

Abstract
The Bluetooth protocol has become ubiquitous, supporting a wide range of devices from personal gadgets like headphones and smartphones to complex systems in automotive and IoT environments. While Bluetooth's flexibility and performance have been thoroughly validated, an overlooked attack surface exists within the protocol's underlying state machines.

This study uncovers Bluetooth vulnerabilities by analyzing state machine mechanisms in various applications, including automotive and mobile devices. Unlike prior research, which primarily focuses on traditional Bluetooth security issues—such as buffer overflows or crashes triggered by malformed packets in the protocol's Type-Length-Value (TLV) structure—our work delves into the complexities of state machine interactions among supported profiles within the protocol stack. By carefully examining state machine sequences and their interdependencies, we attempt to break the standard execution order and reconfigure protocol interaction states, thereby opening a new path for Bluetooth protocol vulnerability discovery.

Since state machine-based vulnerabilities often do not produce visible logs or crash data, they frequently evade detection. We will provide in-depth insights into techniques for manipulating Bluetooth state machine interactions, focusing on systematic methods for discovering these vulnerabilities and assessing their impact on the Bluetooth ecosystem.

Presentation Outline – NOTE THE DETAILED OUTLINE

1. Introduction to Bluetooth Protocol State Machines

1.1 Analysis of State Machine Interaction Processes in L2CAP, SDP, AVRCP, OBEX, LE Audio, etc.

Summary: Bluetooth includes numerous profiles, each with its unique functions and independent state machine. Each layer of the state machine has its distinct characteristics. Here, we will focus on analyzing the interaction mechanisms of some typical protocol state machines to provide a detailed understanding of Bluetooth's state machine operations. This includes how the kernel and drivers handle these messages.

2. Unexplored Features of Bluetooth Protocols

2.1 The Impact of CoD Attributes on Bluetooth Protocol Interactions

Summary: CoD (Class of Device) can be understood as an identifier attribute for Bluetooth devices. In our research, different CoD values prompt peer devices to request different services, potentially triggering distinct protocol flows. On certain devices, varying CoD attributes may lead to different authentication modes. This section will help the audience understand the often-overlooked but critical role of CoD in Bluetooth protocol interactions.

2.2 Triggering "Rare States" in Bluetooth Protocols

Summary: When manufacturers implement Bluetooth functionality, they often modify the protocol stack to better align with their product features. However, due to the broad structure of the protocol stack, many unexplored data points can lead to rare protocol interaction states, which can create various security risks. In this section, we will introduce our innovative "DSF (State-Aware)" algorithm, designed to help identify these rare states in protocol interactions and uncover new, previously unknown attack vectors.

3. "Breaking and Reassembling State Machines in Bluetooth Vulnerability Discovery"

3.1 "Delayed Frame Injection"

Summary: For example, after establishing an L2CAP connection, we can introduce a delay before sending subsequent packets or disrupt the process during critical request or authentication phases. This can lead to issues such as race conditions or deadlocks in device interactions. More advanced is our "dynamic delay" approach, which inserts varying delays at different protocol stages, such as during request and authentication, response waiting, or encryption and decryption phases. This helps ensure thorough protocol coverage and uncovers more issues.

3.2 "Channel Parallelism"

Summary: "Channel parallelism" is a valuable method we identified for vulnerability discovery. Traditional Bluetooth security research focuses on specific protocol data formats, TLV structures, and packet fragmentation but rarely explores multi-channel vulnerabilities. In Bluetooth, multi-channel creation involves establishing multiple logical channels on a single physical Bluetooth connection to simulate multiple data streams. For example, multiple CoC requests in L2CAP or concurrent OBEX channels within AVRCP. In this section, we'll explain how we applied these unique techniques across different platforms (Android/QNX/iOS) to identify critical remote vulnerabilities.

3.3 Discovery and Detection of Logical Vulnerabilities

Summary: By combining the above techniques, we identified not only traditional issues like memory leaks and race conditions but also logic vulnerabilities caused by state machine errors in specific devices. Given the complexity and depth of logic processing across numerous Bluetooth profiles, this section will explore vulnerabilities in the Blue protocol stack itself and how we leverage these alongside target device vulnerabilities for 0-click attacks on certain devices.

Is This Content New (Not Previously Presented/Published)?

New

Have You/Do You Plan to Submit This Talk to Another Conference?

No

What new research, concept, technique, or approach is included in your submission?

1. Instead of focusing on discovering vulnerabilities through mutation of Bluetooth protocol data formats, we propose a novel attack path that leverages state awareness combined with breaking and reassembling protocol state machines to uncover unknown Bluetooth vulnerabilities.
2. Through this topic, users can gain a new perspective on vulnerability discovery: instead of focusing solely on protocol data formats, they can explore new ideas from protocol characteristics and interaction states, including kernel and driver processing flows. This broadens the scope of vulnerability research horizontally, paving the way for discovering new paths in unexplored areas of vulnerability research.

Provide 3 Audience Takeaways.

1. In this presentation, the audience will be able to directly reproduce and try out the vulnerability discovery methods we propose, as we demonstrate the specific implementation process of breaking and reassembling state machines using Python.
2. The audience can also replicate how to detect new protocol attack paths through DSF (State Awareness) technology using programming languages.
3. Viewers will gain insights into the key points, methods, and approaches for auditing the characteristics of entire protocol stack interactions.

If applicable, what problem does your research solve?

1. Discovered a new approach for Bluetooth protocol vulnerability research.
2. Introduced the reassembly & disruption of protocol state machines as a new perspective in protocol vulnerability discovery.
3. Vulnerability research through protocol state interactions enables optimal test coverage.

Will You Be Releasing a New Tool? If Yes, Describe the Tool.

No

Is This a New Vulnerability? If Yes, Describe the Vulnerability.

Yes

1. **Zero-click Remote Access to Phone Contacts Vulnerability**: Typically, pairing a phone requires mutual authentication to establish a full connection and communication. Even with mutual authentication, access to contacts is not granted unless the "Contacts" permission is explicitly given. However, in our research, we found that some phone drivers initiate different authentication processes based on the requesting device's Class of Device (CoD) attribute. Practically, most Bluetooth clients perform a two-step environment scan: they first identify all nearby Bluetooth devices and detect their "Class". Generally, devices searching for "Network Access Point" services scan only those with "network" in their primary service class. We retrieved all matching classes from the device/service CoD and interacted with the phone using different class attributes. To our surprise, we found that with certain CoD class values, mutual authentication could be bypassed. Then, by sending a carefully crafted PBAP Bluetooth request to the target device, we could access the contact list directly, without any interaction or authentication. After reporting and following up with the manufacturers, we learned that the different authentication methods were implemented to enhance the user experience, allowing phones to automatically recognize car devices and skip full authentication for easier Bluetooth connections while driving.

Demo video: redacted

2. **Remote Activation of Music App Without Authentication or Interaction**: We discovered a vulnerability on certain smartphones that allows remote activation of the music app without any authentication or interaction. In addition to the traditional AVRCP protocol, Bluetooth includes an audio control protocol called Bluetooth_AVRCP-Browsing, which is less widely understood. To complete this exploit chain, two vulnerabilities are needed. First, in BlueZ, to send unauthenticated AVRCP requests, we modified parts of the BlueZ protocol stack that handle AVRCP commands, allowing us to send AVRCP commands without authentication. Second, when the device receives a "play/pause" command, it should reject it. However, due to a lack of secondary validation on the connection state, certain devices automatically trigger the play command when browsing audio files via AVRCP-Browsing, even if the device is idle or locked.

Demo video: redacted

3. **Denial of Service in Bluetooth OBEX Protocol**: We discovered a vulnerability in the Bluetooth OBEX protocol that

allows the OBEX service on the target device to become continuously unavailable after handling an OBEX file request (regardless of whether the request is accepted or rejected). By crafting a malicious OBEX file transfer request, we leveraged specific protocol behaviors during request handling, causing the device to enter a blocked state. OBEX protocol is designed to maintain connections during file transfers. However, if the protocol lacks proper timeout mechanisms or error handling, the OBEX service on the target device may enter a "resource-locked" state, preventing it from receiving other files.
Demo video: redacted
4. **Exploiting Rare Conditions in Bluetooth Protocols Through Race Conditions**: Most previous Bluetooth vulnerability research focuses on RFC protocol and message format (TLV) vulnerabilities across various Bluetooth sub-protocol profiles. However, unless a new profile is introduced or packet fragmentation is manipulated effectively, finding such vulnerabilities is increasingly challenging. In our exploration of Bluetooth logic vulnerabilities, we found a significant race condition issue. This occurs when attempting to interact with a device using the AVRCP protocol while simultaneously sending an OBEX file transfer command to the same IVI (in-vehicle infotainment) system, leading to a crash. Unlike TCP, which can initiate simultaneous socket connections, Bluetooth is a point-to-point protocol that does not natively support simultaneous socket connections. To exploit this, we set different Bluetooth protocol profiles as individual packet senders and invoked them within a unified state machine, allowing us to trigger two different profile packets almost simultaneously, causing a crash.
Demo video: redacted
5. **DoS in Tesla Bluetooth Service via L2CAP Authentication Protocol**: We discovered a vulnerability in Tesla's Bluetooth service that allows a remote attacker to crash and continuously reset the Tesla Bluetooth service without any user interaction. This issue occurs in the L2CAP security authentication protocol. The normal authentication protocol state flow is: Create Connection -> Connection Complete -> Remote Name Request Complete -> AuthReq. This issue specifically occurs in the AuthReq process; by repeatedly triggering the AuthReq state within the state machine, the device cannot enter the SetConnEncryption stage, resulting in a continuous service crash and denial of service (DoS).
Demo video: redacted
6. **Severe Logic Vulnerability Affecting All OSs**: We discovered a severe logic vulnerability, potentially affecting all operating systems. This allows us to seamlessly connect to a user's device without their knowledge by hijacking a legitimate Bluetooth hotspot, achieving a success rate of about 70%. We reported this to Bluetooth SIG, but they indicated that it's an issue for Android and automotive developers due to the lack of MITM protection. We also reported this to Android, which suggested forwarding it to downstream manufacturers, as drivers are typically implemented by them. We additionally discovered a critical logic issue in the AVRCP-Browsing protocol. The exploit mechanism is intriguing—we disrupted the AVRCP-Browsing protocol's state machine, causing an authentication request that should occur after connection establishment to be sent right after the initial connection request. This caused parsing logic errors in the car's IVI (in-vehicle infotainment) system, disabling all services related to AVRCP, such as navigation audio, music playback, and phone calls. To restore these services, the car battery must be disconnected.
Demo video: redacted
7. **New Vulnerability in iOS 18**: We identified a new vulnerability in the latest iOS 18 release. This vulnerability was triggered using our protocol state logic defect detection method, which requires manipulating multiple Bluetooth states to directly trigger an error in iOS 18.
Demo video: redacted
8. **High-Power Remote Destructive Vulnerability in OneKey Hardware Wallet**: We also discovered a high-power remote destructive vulnerability in the latest OneKey hardware wallet. Using this method, the device can be "bricked" without any interaction or physical contact, taking at least two hours to reboot.
Demo video: redacted
Our entire research is based on "state machine reassembly". As outlined in our CFP summary, traditional Bluetooth vulnerability discovery typically relies on fuzzing the TLV format, but no one has previously explored how we can leverage protocol interaction state machines to go beyond fuzzing. Our approach is to study state machines, analyze them across different Bluetooth profiles, reassemble them, and discover critical Bluetooth protocol vulnerabilities.
9. **Combining Flaws in Pairing and Authentication Processes**: Some cases involve pairing and authentication processes, combining two parts: 1) we analyze flaws within BlueZ itself, where certain branches of the AVRCP profile lack proper access control and authentication, leaving essential checks and controls absent; 2) we exploit these inherent protocol stack flaws to uncover vulnerabilities in the target system or device. Combining these two methods ultimately achieves RCE (Remote Code Execution)

If this is a new vulnerability, have you disclosed it to the affected vendor(s)?
We have discovered and submitted multiple CVEs using our methodology, including CVE-2022-38685, CVE-2023-33901, and CVE-2023-33902. Additionally, we have submitted other vulnerabilities that have not yet been assigned CVEs due to their significant impact; the vendors are aware and have already fixed them. For the vulnerability discovered in iOS 18, Apple's latest response indicates that they are investigating the root cause of the issue and will apply for a CVE number only after a complete fix is implemented.

Will Your Presentation Include a Demo? If Yes, Describe the Demo.

1. **Zero-click Remote Access to Phone Contacts Vulnerability**: Typically, pairing a phone requires mutual authentication to establish a full connection and communication. Even with mutual authentication, access to contacts is not granted unless the "Contacts" permission is explicitly given. However, in our research, we found that some phone drivers initiate different authentication processes based on the requesting device's Class of Device (CoD) attribute. Practically, most Bluetooth clients perform a two-step environment scan: they first identify all nearby Bluetooth devices and detect their "Class". Generally, devices searching for "Network Access Point" services scan only those with "network" in their primary service class. We retrieved all matching classes from the device/service CoD and interacted with the phone using different class attributes. To our surprise, we found that with certain CoD class values, mutual authentication could be bypassed. Then, by sending a carefully crafted PBAP Bluetooth request to the target device, we could access the contact list directly, without any interaction or authentication. After reporting and following up with the manufacturers, we learned that the different authentication methods were implemented to enhance the user experience, allowing phones to automatically recognize car devices and skip full authentication for easier Bluetooth connections while driving.
   Demo video: redacted
2. **Remote Activation of Music App Without Authentication or Interaction**: We discovered a vulnerability on certain smartphones that allows remote activation of the music app without any authentication or interaction. In addition to the traditional AVRCP protocol, Bluetooth includes an audio control protocol called Bluetooth_AVRCP-Browsing, which is less widely understood. To complete this exploit chain, two vulnerabilities are needed. First, in BlueZ, to send unauthenticated AVRCP requests, we modified parts of the BlueZ protocol stack that handle AVRCP commands, allowing us to send AVRCP commands without authentication. Second, when the device receives a "play/pause" command, it should reject it. However, due to a lack of secondary validation on the connection state, certain devices automatically trigger the play command when browsing audio files via AVRCP-Browsing, even if the device is idle or locked.
   Demo video: redacted
3. **Denial of Service in Bluetooth OBEX Protocol**: We discovered a vulnerability in the Bluetooth OBEX protocol that allows the OBEX service on the target device to become continuously unavailable after handling an OBEX file request (regardless of whether the request is accepted or rejected). By crafting a malicious OBEX file transfer request, we leveraged specific protocol behaviors during request handling, causing the device to enter a blocked state. OBEX protocol is designed to maintain connections during file transfers. However, if the protocol lacks proper timeout mechanisms or error handling, the OBEX service on the target device may enter a "resource-locked" state, preventing it from receiving other files.
   Demo video: redacted
4. **Exploiting Rare Conditions in Bluetooth Protocols Through Race Conditions**: Most previous Bluetooth vulnerability research focuses on RFC protocol and message format (TLV) vulnerabilities across various Bluetooth sub-protocol profiles. However, unless a new profile is introduced or packet fragmentation is manipulated effectively, finding such vulnerabilities is increasingly challenging. In our exploration of Bluetooth logic vulnerabilities, we found a significant race condition issue. This occurs when attempting to interact with a device using the AVRCP protocol while simultaneously sending an OBEX file transfer command to the same IVI (in-vehicle infotainment) system, leading to a crash. Unlike TCP, which can initiate simultaneous socket connections, Bluetooth is a point-to-point protocol that does not natively support simultaneous socket connections. To exploit this, we set different Bluetooth protocol profiles as individual packet senders and invoked them within a unified state machine, allowing us to trigger two different profile

packets almost simultaneously, causing a crash.
Demo video: redacted

5. **DoS in Tesla Bluetooth Service via L2CAP Authentication Protocol**: We discovered a vulnerability in Tesla's Bluetooth service that allows a remote attacker to crash and continuously reset the Tesla Bluetooth service without any user interaction. This issue occurs in the L2CAP security authentication protocol. The normal authentication protocol state flow is: Create Connection -> Connection Complete -> Remote Name Request Complete -> AuthReq. This issue specifically occurs in the AuthReq process; by repeatedly triggering the AuthReq state within the state machine, the device cannot enter the SetConnEncryption stage, resulting in a continuous service crash and denial of service (DoS).
   Demo video: redacted
6. **Severe Logic Vulnerability Affecting All OSs**: We discovered a severe logic vulnerability, potentially affecting all operating systems. This allows us to seamlessly connect to a user's device without their knowledge by hijacking a legitimate Bluetooth hotspot, achieving a success rate of about 70%. We reported this to Bluetooth SIG, but they indicated that it's an issue for Android and automotive developers due to the lack of MITM protection. We also reported this to Android, which suggested forwarding it to downstream manufacturers, as drivers are typically implemented by them. We additionally discovered a critical logic issue in the AVRCP-Browsing protocol. The exploit mechanism is intriguing—we disrupted the AVRCP-Browsing protocol's state machine, causing an authentication request that should occur after connection establishment to be sent right after the initial connection request. This caused parsing logic errors in the car's IVI (in-vehicle infotainment) system, disabling all services related to AVRCP, such as navigation audio, music playback, and phone calls. To restore these services, the car battery must be disconnected.
   Demo video: redacted
7. **New Vulnerability in iOS 18**: We identified a new vulnerability in the latest iOS 18 release. This vulnerability was triggered using our protocol state logic defect detection method, which requires manipulating multiple Bluetooth states to directly trigger an error in iOS 18.
   Demo video: redacted
8. **High-Power Remote Destructive Vulnerability in OneKey Hardware Wallet**: We also discovered a high-power remote destructive vulnerability in the latest OneKey hardware wallet. Using this method, the device can be "bricked" without any interaction or physical contact, taking at least two hours to reboot.
   Demo video: redacted
   Our entire research is based on "state machine reassembly". As outlined in our CFP summary, traditional Bluetooth vulnerability discovery typically relies on fuzzing the TLV format, but no one has previously explored how we can leverage protocol interaction state machines to go beyond fuzzing. Our approach is to study state machines, analyze them across different Bluetooth profiles, reassemble them, and discover critical Bluetooth protocol vulnerabilities.
9. **Combining Flaws in Pairing and Authentication Processes**: Some cases involve pairing and authentication processes, combining two parts: 1) we analyze flaws within BlueZ itself, where certain branches of the AVRCP profile lack proper access control and authentication, leaving essential checks and controls absent; 2) we exploit these inherent protocol stack flaws to uncover vulnerabilities in the target system or device. Combining these two methods ultimately achieves RCE (Remote Code Execution)

Provide the Names of the Speakers Presenting and Their Previous Speaking Experience.
LidongLi：POC2018 Speaker/HITB 2019Speaker/Kcon Speaker/ISC Speaker; Xiao Wang

Does Your Company/ Employer Provide a Solution to the Issue Addressed? If Yes, Please Provide Details.
We will provide a general solution approach and the root cause of the vulnerability (if requested by the vendor), while the vendor will handle the code remediation phase independently.

Do You Want to Provide a White Paper for Review by the Board?
No

Black Hat Asia 2025 – Example of High Scoring Submission

Proposal Info

Title
JDD: In-depth Mining of Java Deserialization Gadget Chains via Bottom-up Gadget Search and Dataflow-aided Payload Construction

Status
Accepted

Session Type
Briefings

Speakers
Bofei Chen, (Ph.D Candidate, Fudan University)
Yinzhi Cao, (Associate Professor, Johns Hopkins University)

Additional Contributors
Lei Zhang, (Assistant Professor, Fudan University)
Xinyou Huang, (Master's Student, Fudan University)
Yuan Zhang, (Professor, Fudan University)
Min Yang, (Professor, Fudan University)

Tracks
Application Security: Offense; Exploit Development & Vulnerability Discovery

Format
40-Minute Briefings

Abstract
Java serialization and deserialization facilitate cooperation between different Java systems, enabling convenient data and code exchange. However, a significant vulnerability known as Java Object Injection (JOI) allows remote attackers to inject crafted serialized objects, triggering internal Java methods (gadgets) and resulting in severe consequences such as remote code execution (RCE). Previous works have attempted to detect and chain gadgets for JOI vulnerabilities using static searches and dynamic payload construction via fuzzing. However, these methods face two key challenges: (i) path explosion in static gadget searches and (ii) a lack of fine-grained object relations connected via object fields in dynamic payload construction.
- First, we introduce a gadget fragment-based summary and bottom-up search approach to address the path explosion challenge.
- Second, we then demonstrate how to infer the dataflow dependencies between injection objects' fields and use them to guide dynamic fuzzing to generate exploitable objects.

We evaluate JDD upon six popular Java applications (e.g., Apache Dubbo, Sofa-RPC, Solon, etc) in their latest version, which finds 127 zero-day exploitable gadget chains with six Common Vulnerabilities and Exposures (CVE) identifiers assigned (i.e., CVE-2023-35839, CVE-2023-29234, CVE-2023-39131, CVE-2023-48967, CVE-2024-23636, and CVE-2023-41331).
Each of these CVEs has a CVSS score of 9.8, indicating an extremely high risk of exploitation and the potential to cause significant security damage. Given the wide range of impacts and potential consequences of these vulnerabilities, the related developers patched all these gadget chains in a prompt and timely manner after we reported our findings.

Presentation Outline – NOTE THE DETAILED OUTLINE
/ Brief outline **/**

Introduction
Background and Technique challenges
Challenge I: path explosion in static gadget searches.
Challenge II: complex object field relations.
Methodology
Stage I: Gadget fragment-based summary and bottom-up gadget searching approach.
Step 1: Identifying deserialization entry points.
Step 2: Identifying gadget fragments with static taint analysis.
Step 3: Linking gadget fragments to construct gadget chains using a bottom-up approach.
Stage II: Dataflow-aided injection object generation.
Step 4: Constructing IOCD based on Injection Object related Constraints.
Step 5: IOCD-enhanced Directional Fuzzing.
Evaluation and Interesting zero-day gadget chains
Takeaways + Q&A

/ Detailed outline **/**

Part I: Introduction

In this (brief) part of the talk, we will highlight:
1. First, we will introduce the threat model for Java deserialization vulnerabilities and the importance of detecting and defending against this type of vulnerability.
2. Second, we will discuss the powerful evolutionary capabilities of Java deserialization gadget chains and the wide range of incompletely fixed patching problems they cause.
Java deserialization vulnerability is typically assigned extremely high-risk ratings and governance priorities given their broad reach and serious potential consequences. However, since deserialization is a fundamental mechanism, developers are often unable to directly block the entire gadget chain to ensure that normal business functions are not affected. Coupled with the dynamic features of Java and the widespread use of third-party components, the attackers could find many alternatives for the blocked gadgets in the patch and bypass existing defenses, resulting in long-term security risks.

Part II: Background and Technique challenges

In this part, we will first introduce how to exploit the Java deserialization vulnerability through a motivating example.
- Typically, an attacker would first find a gadget chain, which is an execution path that can invoke a security-sensitive method.
- Then, the attacker constructs an injection object, and sends it to the target server to trigger the gadget chain and achieve attack consequences.
Next, we will briefly outline the detection methods employed in previous research. Finally, we will summarize the challenges that remain unaddressed by existing prior works, using this example as a basis.
A. Path explosion. Prior works often adopted a top-down static approach for checking gadgets extensively from a source to a sink for potential paths. However, during the search process, it is easy to detect many dynamic method calls that an attacker can control. As a result, top-down candidate search methods may grow exponentially with the search length and suffer from a severe path explosion problem. Thereby, the construction space of gadget chains cannot be fully explored in a limited time, leading to a large number of underreporting.
B. Complex object field relations. To trigger the attacker's expected method invocation sequence, the injected object usually has complex parallel and embedded object structure and field-related constraints and dependencies. Thus, it is difficult for random mutations to generate a valid payload to validate the gadget chains' exploitability.

Part III: Methodology

To address these two challenges, we designed an advanced automated JOI vulnerability detection tool called JDD, which was presented at IEEE Symposium on Security and Privacy 2024. It consists of two main stages with five steps. In Stage I, JDD detects possible gadget chains. Then, JDD generates injection objects to verify the gadget chains' exploitability. Below, we will elaborate on the solution crafted to overcome the aforementioned technical challenges.
Stage I: Gadget fragment-based summary and bottom-up gadget searching approach
- Step 1. JDD extracts entry points from both the deserialization methods of Java language and popular Java

deserialization protocols.
- Step 2. JDD detects useful gadget fragments that could be chained together to construct gadget chains from entry points using static analysis. First, JDD starts from each source until the next dynamic method invocation and treats code in between as a fragment. Then, for each fragment, JDD performs data-flow analysis to record the taint mapping relationship between the last method and the first method parameters in the fragment, as well as the conditions on how to link the fragment.
- Step 3. Upon completing the search of gadget fragments, JDD performs a bottom-up search to chain fragments together, thereby constructing all potential gadget chains. Our key idea is to fully reuse known sink knowledge (sink reachability, exploit conditions, etc.) to reduce repetitive analyses and thus reduce search complexity.
Stage II: Dataflow-aided injection object generation
Then, we will introduce how to generate injection objects for each gadget chain. and verify the exploitability of the chain by detecting whether the object can trigger the expected attack behavior.
- Step 4. JDD follows the call sequence of the detected gadget chain to extract the execution paths, and then uncovers constraints that affect inputs. After extracting these constraints, JDD uses a novel data structure, termed Injection Object Construction Diagram (\textit{IOCD}) to model the object structure and dependencies of fields.
- Step 5. JDD first generates an initial seed with a suitable structure based on the IOCD. Then, JDD utilizes IOCD to enhance the efficiency of fuzzing from three aspects: (i) select appropriate fields for mutation. (ii) reduce the uncertain mutation space through constraint information. And (iii) ensure that the validity of the overall structure of the object is not compromised via a dependency-aware seed mutation.
Part IV: Evaluation and Interesting zero-day gadget chains
We evaluated the effectiveness of JDD on known datasets and popular Java components in the real world.
Firstly, we employed JDD to analyze the latest versions of several popular Java open-source components, including Apache Dubbo, Sofa-RPC, Solon, Motan, etc. JDD discovered 127 zero-day exploit chains, earning recognition and acknowledgments from the respective vendors. Six Common Vulnerabilities and Exposures (CVE) identifiers were assigned to these discoveries, including CVE-2023-35839, CVE-2023-29234, CVE-2023-39131, CVE-2023-48967, CVE-2024-23636, and CVE-2023-41331. Each of these CVEs has a CVSS score of 9.8, indicating a very high risk of exploitation and the potential to cause serious security harm. Due to the extensive impact and severe potential consequences of these vulnerabilities, developers have patched all of them.
Additionally, we compared JDD with existing approaches such as ODDFuzz, GCMiner, and GadgetInspector using the well-known gadget chain dataset, i.e., ysoserial. The experimental results show that JDD detects 91 additional, previously undisclosed exploit chains compared to the current state-of-the-art tools.
In addition, we will also share some interesting zero-day exploitable gadget chains detected by JDD.
- Further explain the strong derivability of such vulnerabilities. Attackers could find many alternatives for the blocked gadgets in the patch and derive new exploitable gadget chains from the original ones; or use them to attack other Java projects that rely on different third-party components.
- Illustrate the expanded attack vectors of some unknown gadget chains detected by JDD in comparison to the known chains. For example, if the gadget chain relies on fewer and more commonly used Java dynamic features, there may be more protocols it can exploit.
Part V: Finally, we will wrap up with key takeaways, leaving 5 minutes for questions.
We'll also summarize the talk's key points and the tools presented.
- Two core technical challenges that previous state-of-the-art gadget chain detection tools failed to effectively address.
- A fragment-based summary and bottom-up gadget chain detection approach that effectively tackles the challenge of static path explosion.
- A technical framework that utilizes a lightweight static taint anal

Is This Content New (Not Previously Presented/Published)?
No. JDD was published at IEEE Symposium on Security and Privacy 2024, a prestigious conference in the cybersecurity field. Paper URL: redacted

Have You/Do You Plan to Submit This Talk to Another Conference?
Conference: IEEE Symposium on Security and Privacy 2024, a prestigious conference in the cybersecurity field.
/** What's new **/

In this talk, we will share more detailed schema design, tool implementation, and usage insights:
- Provide more details on how to (1) generate summaries for gadget fragments;
(2) link gadget fragments via a bottom-up search; and (3) generate exploitable injection objects based on IOCDs
- We will share more interesting zero-day gadget chains detected by JDD.

What new research, concept, technique, or approach is included in your submission?
We design a novel gadget chain detection framework, called JDD, to statically detect possible gadget chains using a bottom-up approach and dynamically generate payloads, i.e., exploitable injection objects, relying on dataflow relations between object fields. JDD addresses the two key technique challenges in Java deserialization gadget chain detection.
- JDD solves the path explosion problem of static search for chained gadgets via a bottom-up approach that discovers intermediate gadget fragments and then chains them together from sinks to sources.
- JDD constructs the so-called Injection Object Construction Diagram (IOCD) to better model dataflow dependencies between object fields and assist dynamic fuzzers for payload construction.

Provide 3 Audience Takeaways.
- Two core technical challenges that previous state-of-the-art gadget chain detection tools failed to effectively address.
- A fragment-based summary and bottom-up gadget chain detection approach that effectively tackles the challenge of static path explosion.
-A technical framework that utilizes a lightweight static taint analysis engine to drive directed fuzzing.

If applicable, what problem does your research solve?
Lack of effective automatic tools for Java deserialization gadget chain detection and exploitable injection object generation. JDD could more comprehensively explore the construction space of gadget chains, thereby offering developers more insightful solutions for addressing Java deserialization vulnerabilities. For example, JDD could assist developers in designing and verifying blacklists and whitelists. This ensures they effectively block all potential exploit chains to the greatest extent possible.

Will You Be Releasing a New Tool? If Yes, Describe the Tool.
Yes. We released JDD, an automated tool for Java deserialization gadget chain detection and injection object generation.

Is This a New Vulnerability? If Yes, Describe the Vulnerability.
Yes. JDD detected 127 zero-day gadget chains and was assigned 6 CVE IDs.
(CVE-2023-35839, CVE-2023-29234, CVE-2023-39131, CVE-2023-48967, CVE-2024-23636, and CVE-2023-41331)
Their descriptions are listed separately below.
CVE-2023-35839: SOFARPC defaults to using the SOFA Hessian protocol to deserialize received data, while the SOFA Hessian (< 5.12.0) protocol uses a blacklist mechanism to restrict deserialization of potentially dangerous classes for security protection. But there is a gadget chain that can bypass the SOFA Hessian blacklist protection mechanism, and this gadget chain only relies on JDK and does not rely on any third-party components.
CVE-2023-48967: solon

If this is a new vulnerability, have you disclosed it to the affected vendor(s)?
Yes, the related developers patched all these vulnerabilities after we reported our findings.
For example: CVE-2023-39131
vendor response: Thanks for the feedback, we will evaluate whether to replace the native hessian with a third-party hessian library such as SOFA-Hessian.
reporting status: reported
timelines: May 22, 2023 -- May 28, 2023
patch status: patched.
For example: CVE-2024-23636
vendor response: We are currently working on the fix and should be able to release the patch next week.
sofa-rpc 5.12.0 was released to fix the RCE attack. The CVE issued is CVE-2024-23636.
timelines: Nov 10, 2023 -- Jan 24

reporting status: reported
patch status: patched.

Will Your Presentation Include a Demo? If Yes, Describe the Demo.
Yes. We plan to demo the process of JDD detecting Java deserialization gadget chains and generating exploitable injection objects for them. This will help attendees understand the JDD workflow more intuitively.

Provide the Names of the Speakers Presenting and Their Previous Speaking Experience.
Bofei Chen, Yinzhi Cao. No previous speaking experience.

Does Your Company/ Employer Provide a Solution to the Issue Addressed? If Yes, Please Provide Details.
No. We are independent researchers.

Do You Want to Provide a White Paper for Review by the Board?
Yes – http://i.blackhat.com/docs/Black-Hat-Sample-White-Paper-Efficient-Detection-of-Java-Deserialization.pdf

Black Hat Asia 2025 – Example of High Scoring Submission

Proposal Info

Title
The ByzRP Solution: A Global Operational Shield for RPKI Validators

Status
Accepted

Session Type
Briefings

Speakers
Donika Mirdita, (Security Researcher, Technical University Darmstadt | ATHENE)
Jens Frieß, (Security Researcher, Technical University Darmstadt | ATHENE)

Additional Contributors
Haya Schulmann, (Professor, Goethe University Frankfurt | ATHENE)
Michael Waidner, (Professor, Technical University Darmstadt | ATHENE | Fraunhofer SIT)

Tracks
Network Security; Application Security: Defense

Format
40-Minute Briefings

Abstract
The Border Gateway Protocol (BGP) is the core routing protocol on the Internet, but it lacks security mechanisms. At the same time, the democratization of access has transformed the Internet into the default platform, where global services and communications happen. As a result, routing security quickly became an issue of great economic and national security concern. The US Federal Communications Commission and the White House Office of the National Cyber Director formally recognized the urgent need to invest more on protecting Internet routing, and standardize efficient security protocols.

The Resource Public Key Infrastructure (RPKI) protocol is rapidly becoming the global standard for enforcing Internet routing security for BGP. It currently covers over 50% of IPv4 and IPv6 prefixes and has been deployed by at least 27% of networks in the world, including major Tier-1 providers. However, RPKI is not secure by design. Research on its robustness and security properties has shown that despite the minimal public facing interfaces, RPKI suffers from widespread crash-inducing vulnerabilities and exploitable protocol loopholes. Attacks on RPKI have been well-documented over the years, including previous BlackHat talks. Now that RPKI is poised to go global, with the potential of being included into strict security regulations, it is time to reconsider the current vulnerable deployments and improve their robustness.

In this work, we introduce Byzantine RPKI (ByzRP), a secure, robust, and distributed intermediate RPKI service that provides a stable output for all RPKI clients worldwide, while being able to completely bypass stalling and denial-of-service attacks on the RPKI infrastructure, with no downtime and service failure.

Presentation Outline – NOTE THE DETAILED OUTLINE
RPKI's relevance for global Internet security

The presentation will begin with a short history of the RPKI and the remarkable growth in relevance over its 12 years of continuous development. We will introduce the deployment trends of RPKI over the years, and several major instances

of success on the Internet which made international news and led to further deployment by other ISPs that were not yet on board. We will also talk about the different regulatory bodies, government (US White House) or otherwise (NRO), working on standardizing the RPKI and formalizing it as a legally mandatory security protocol to protect BGP. We will also present to viewers why protecting BGP is such an urgent task for (inter-)national security purposes.

A Primer on RPKI functionality and endemic issues that plague it
---
We will introduce the core software, interactions and functionalities of the RPKI as defined in the standards. We will illustrate how the RPKI is globally deployed and then we will describe two attack vectors that can be used to disable RPKI and their consequences on global deployment.
1) Stalling Attacks and how they exploit logical loopholes in the protocol standard, which affect every single RPKI software implementation, and can be used to downgrade RPKI protection for targeted resources.
2) Denial-of-Service attacks that land the RPKI validators in a state of perpetual fail-and-restart, thus disconnecting them from routers and downgrading RPKI protection for all resources worldwide.

Challenges in solving RPKI vulnerabilities

We explore some works that our research group has done in the past in order to mitigate issues in the RPKI software and the RFC standard. We explain why backwards compatibility is vital for any serious solution to the RPKI issues, due to the already successful RPKI deployment worldwide in the current form. Additionally, measurements show that many RP deployers are not updating their software regularly when CVEs and security advisories are issued, so the vulnerabilities in many networks only continue to accrue. Finally, we describe the challenges we faced in coming up with a design that mitigates most issues in the RPKI, is easy to deploy, and offers full backwards compatibility with the current RPKI deployments.

Introducing ByzRP and the design choices

We introduce the stepwise development of ByzRP. The purpose was to develop an infrastructure that mitigates all known issues in the RPKI that affect the functionality and availability of the RPKI validator (otherwise known as Relying Party or RP). We chronologically list the issues discovered during our analysis and what design choices were made to address them.
1) Stalling and DoS attacks -> This was known from our previous work, so we developed the validator-adjacent security monitor to deal with these issues and ensure the RPKI validators are never downgraded from operating for a meaningful amount of time. We decouple the mechanism that offers outputs to clients from the health of a single RPKI validator, thus ensure connections with routers remain live even under attack.
2) Network jittering and output instability -> We discovered this as we were developing our solution. To mitigate this issue we improved our framework to include distributed nodes that redundantly perform RPKI validation and introduced a peering and consensus mechanism so that we maximize the stability and correctness of the output, and avoid transient network errors.
3) Centralization of validators, risk of censorship -> As we developed our system, we realized it could be further improved to provide a decentralized censorship resistant system so we reshaped the peering network to a byzantine-secure distributed permissioned network.
We designed ByzRP so that it can be set up and deployed by any interested provider entity as a service (RP-as-a-Service) and can offer a robust alternative to using standalone RPKI validators.

ByzRP Evaluation and live demonstration

We test and evaluate our framework to make sure that it delivers the aforementioned security guarantees. We will show the results and graphs of our different evaluations to prove ByzRP's efficiency and security i.e. we will show that ByzRP continues to function normally even when under active attack, that would otherwise incapacitate a standard operating RP. We will also provide analysis of the longterm performance of our system and an efficiency comparison of our live deployment with a standalone RPKI validator deployment, as the industry currently uses it.

Information Classification: General

Conclusion

We conclude our presentation with a summary of the ever-increasing relevance of network security in the global security theater and how RPKI is quickly becoming an integral protocol to ensure said security. We highlight the various (known) vulnerabilities of RPKI and how they can become major issues in RPKI fulfilling this critical role down the line. We describe a roadmap that anyone who wants to improve RPKI security can use to inform their future research, and introduce ByzRP as our attempt to offer a solution that mitigates all RPKI vulnerabilities, while still being 100% backwards compatible with the existing standard and current RPKI deployments.

Blackhat Soundbites

The most important insights and contributions of our work are:
- RPKI is quickly becoming the defacto BGP security protocol, however, vulnerabilities in the protocol are well-known and current work in mitigating them remains purely theoretical and academic due to lack of compatibility with the standard.
- ByzRP is a comprehensive architecture that can be offered as an online service (RP-as-a-Service) that mitigates all known RPKI vulnerabilities, while remaining fully backwards compatible with the existing RPKI deployment, thus facilitating the spread of a robust solution without compromising the current deployment trends.
- Outsourcing RP functionality to entities dedicated to offering a safe, robust, byzantine-secure distributed RP-as-a-Service, increases global RPKI security by decreasing an adversary's capability to model RPKI infrastructure and launch dedicated attacks.

Is This Content New (Not Previously Presented/Published)?
The theoretical PoC of our approach was already published and presented in the conference ACM CCS 2024.

Have You/Do You Plan to Submit This Talk to Another Conference?
The theoretical PoC of our approach was already presented in the conference ACM CCS 2024.

What new research, concept, technique, or approach is included in your submission?
The most novel concept is the combination of multiple enhanced RP instances in a permissioned consensus network. Integrating the results of multiple validators protects the routers that use this data from individual RP outages, crashes or stalling, as well as transient outages of RPKI repositories and transient unavailability of individual RPKI objects. This leads to more reliable and consistent data, as well as better availability.
Furthermore, the consensus is Byzantine-secure, meaning that up to half of the nodes can fail or misbehave without affecting the security of the network. This paves the way for network operators to use a global RP-as-a-service network, because trust is distributed across all the participants in the network; no individual 3rd party needs to be trusted. Such an RP-as-a-service network would drastically reduce RPKI-related traffic, because fewer RPs are running on the internet, and remove the burden on network providers of maintaining their own RP.

Provide 3 Audience Takeaways.
- RPKI is on its way to becoming a globally enforced security protocol but it is vulnerable to various attack vectors and most of the research being done to improve it lacks backwards compatibility. In this work, we provide a blueprint for how to further develop and improve RPKI without breaking compatibility with existing deployment.
- Networks that have adopted RPKI would be better protected from stalling and crashing attacks if they run ByzRP instead of standalone RP implementations. They will also receive a stable output bypassing transient outages and repository jittering.
- Organizations that would like to support a global, heterogeneous, collaborative RP service can run their own ByzRP networks or participate in our live network as additional nodes.

If applicable, what problem does your research solve?
Our research improves the security, robustness, and stability of RPKI validation services, adding resilience to stalling and crashing attacks, as well as transient outages and repository jitter. In addition, it offers a way to outsource the

maintenance cost of running an RP to a distributed external service provider without requiring full trust in any individual node due to byzantine-security properties.

Will You Be Releasing a New Tool? If Yes, Describe the Tool.
Yes, our ByzRP implementation is open-source and available on Github https://github.com/Cyberbruecke/byzrp .

Is This a New Vulnerability? If Yes, Describe the Vulnerability.
No

Will Your Presentation Include a Demo? If Yes, Describe the Demo.
Yes. We will illustrate how an external user can interact with our live system.

Provide the Names of the Speakers Presenting and Their Previous Speaking Experience.
Donika Mirdita, previously presented at BlackHat USA 2024
Jens Frieß, previously presented his work at NSDI 2024

Does Your Company/ Employer Provide a Solution to the Issue Addressed? If Yes, Please Provide Details.
No.

Do You Want to Provide a White Paper for Review by the Board?
This is the conference paper this talk is based on https://dl.acm.org/doi/10.1145/3658644.3690368